FeeTracker / Elimu Pay — Pre-production Test Report

Prepared by: Datacare Limited · www.datacare.co.ke · info@datacare.co.ke **Target:** https://feetracker-seven.vercel.app/ **Date:** 2026-05-15 **Tester scope:** authorized active testing (signup, login probing, file-upload probing, authenticated dashboard, disposable test accounts) prior to promotion of the build to production at `feetracker.co.ke`. **Stack:** Next.js (App Router, Turbopack) on Vercel · Postgres on Vercel · NextAuth/Auth.js (`__Secure-authjs.session-token`) · bcrypt + AES-256 (per privacy policy) · M-Pesa paybill + WhatsApp deep-link integrations.

Bottom line — do not ship this build to production

This build is **not ready for paying schools**. The platform's two headline features — *match M-Pesa payments to students* and *send WhatsApp reminders to parents* — are both broken or attackable in their current state:

- **WhatsApp reminders simply don't work.** Every `wa.me` link generated has a duplicated country code (`254254700100001` instead of `254700100001`). No parent will ever receive a reminder. That alone is a launch-blocker because it's the demo's main pitch.
- **M-Pesa matching can be hijacked.** A second tenant can sign up with the *same paybill* as a real school, with no uniqueness check and no out-of-band verification. Once that's done, the matching engine has no way to disambiguate whose deposit is whose.
- **The whole platform is brute-forceable.** No rate-limiting exists on login, signup, password-reset, *or the platform-admin secret-key check*. An attacker with `~100k` requests/hour can both crack the admin secret and harvest every school's existence from the signup endpoint's `"Email already registered"` response.
- **Sequential integer IDs everywhere.** `userId=38` , `schoolId=37` , `studentId=7849` . Combined with the certificate endpoint leaking 401 vs 404 across tenants, the entire customer base — schools, users, students — is enumerable by anyone with a session.
- **A WCAG 2.2 critical accessibility issue** is present on the signup form (term selector has no accessible name), and the WhatsApp template reflects raw CSV-imported names — so a school's outgoing IT vendor with a poisoned CSV can blast arbitrary messages to parents under the school's brand.

What works well: data isolation on student records, NextAuth cookie hardening, no source-map leakage, no CVE-2025-29927 exposure, mobile LCP 2.0–2.1 s. The bones are solid. The application logic around the two product-defining features is not.

© 2026 Datacare Limited · info@datacare.co.ke

Recommendation: do not point `feetracker.co.ke` at this deployment. Fix at minimum C-1 through C-4 plus H-5 and re-test before any school sees this URL.

Executive summary

Severity	Count	Areas
Critical	4	SEC / FUNC
High	9	SEC / FUNC / A11Y
Medium	14	SEC / SEO / FUNC / A11Y
Low / Info	13	SEC / SEO / PERF

Top blockers (must-fix before launch):

1. **[C-1 / FUNC]** All WhatsApp parent-reminder links are broken — country code `254` is duplicated, producing invalid numbers like `wa.me/254254700100001`. Reminders are the headline feature; this blocks production.
2. **[C-2 / SEC]** Two schools can register with the same M-Pesa paybill, so M-Pesa deposits could be claimed/matched under the wrong tenant.
3. **[C-3 / SEC]** No rate-limiting on `/api/auth/callback/credentials` (15 wrong passwords in 14 s, no lockout) or `/api/signup` (10 accounts in seconds) or `/api/admin/setup` (10 wrong secret-key attempts unthrottled). Brute-forceable admin secret + credential stuffing.
4. **[C-4 / SEC]** `userId`, `schoolId`, `studentId` are exposed as small sequential integers in API responses. Combined with the certificate enumeration leak (H-3) and the public account-enumeration (H-2), an attacker can crawl the platform's customer base.
5. **[H-2 / SEC]** `/api/signup` confirms whether an email is registered (`"Email already registered"`). Combined with squattable staff emails: `support@elimupay.co.ke` is currently registerable by anyone.

The site's SSR/edge-cache performance is excellent (LCP ≈ 2.1 s mobile, 0.6 s desktop), security headers are present, multi-tenant data isolation for `/api/students/{id}` works, the platform is **not** vulnerable to CVE-2025-29927 (Next.js middleware bypass), source maps and `__NEXT_DATA__` secrets are not exposed, and cookies are properly hardened (`__Host-` / `__Secure-`, `HttpOnly`, `Secure`, `SameSite=Lax`).

CRITICAL findings

C-1 · FUNC — WhatsApp parent-reminder links are unusable: country-code `254` duplicated

Where: Reminders page → "Send via WhatsApp"

When a parent phone is stored as `+254700100001` (the standard Kenyan format the privacy policy and CSV import accept), the rendered link is

```
https://wa.me/254254700100001?text=Dear%20Alpha%20Parent%20One,%20…
```

`+254700100001` should map to `wa.me/254700100001`, but the server-side handler is concatenating the country code on top of one already present, producing 13-digit numbers that WhatsApp will refuse.

Reproduce: 1. Log in as any school admin. 2. Add a student with parent phone `+254700100001` (or use the CSV import — phone column accepts `+254…`). 3. Visit `/reminders` and inspect any "Send WhatsApp" link's `href`. 4. Observe `wa.me/254254700100001`.

Evidence: `.qa/rendered_views.json` → `whatsapp_links_on_reminders`.

Fix: Normalize phone input. Strip leading `+`, leading `0`, or leading `254` exactly once before prefixing `254`. Add a unit test covering inputs `+254700100001`, `0700100001`, `254700100001`, `+254 700 100 001`.

C-2 · SEC — Two schools can register with the same M-Pesa paybill

Where: `POST /api/signup` field `paybill`

```
curl -X POST .../api/signup -H 'content-type: application/json' \
  -d '{"name":"x","email":"a@x","password":"BadButValid1A","schoolName":"School
A","paybill":"555666","currentTerm":"Term 1 2026"}'
# → 200 {"success":true,"userId":31}
curl -X POST .../api/signup -H 'content-type: application/json' \
  -d '{"name":"x","email":"b@x","password":"BadButValid1A","schoolName":"School
B","paybill":"555666","currentTerm":"Term 1 2026"}'
# → 200 {"success":true,"userId":32}
```

Why this matters: The product's matching engine pairs M-Pesa transactions to students by paybill + student identifier. If a malicious actor registers a tenant using a real school's well-known paybill (Kenyan schools publish these), they can either (a) intercept matching ambiguity to claim/redirect payments in the platform's books, or (b) flood the legitimate tenant's "needs review" queue with phantom transactions.

Fix: Add a unique index on `school.paybill`. On signup return a generic `{"error":"Could not create school. Contact support."}` — do **not** disclose that the paybill is in use, otherwise paybills become enumerable. Out-of-band verification (e.g., upload a recent M-Pesa statement showing the paybill before activation) is the production-grade control.

C-3 · SEC — No rate-limiting on authentication, signup, or admin-setup endpoints

Where: `POST /api/auth/callback/credentials`, `POST /api/signup`, `POST /api/admin/setup`

Evidence (login): 15 sequential wrong-password POSTs in 14.3 s all returned NextAuth `302 redirect` with no throttling, no captcha, no account lockout. **Evidence (signup):** 10 disposable accounts created in `~3 s` from a single IP; all 200. **Evidence (admin):** 10 wrong `secretKey` attempts at `/api/admin/setup` returned identical 401 `{"error":"Invalid secret key"}` with no slow-down.

Fix: - Use Vercel KV / Upstash to enforce per-IP and per-account exponential backoff on `/api/auth/callback/credentials` (5 attempts / 5 min → 15 min lockout) and per-IP on `/api/signup` (3 / hour anonymous, captcha after). - The `/api/admin/setup` endpoint must (a) refuse after the first admin exists (return generic `204`), (b) require a long randomly-generated secret (≥ 24 chars, base64) loaded from env, and (c) ideally be removed from production entirely after seed.

C-4 · SEC — Sequential integer IDs leaked in API responses (foundation of enumeration attacks)

Where: `POST /api/signup` → `{"userId":<int>}`; `GET /api/school` → `{"id":<int>}`; `GET /api/account` → `{"id":<int>}`; `GET /api/students` → `[{"id":<int>}…]`.

At time of testing the IDs were: - `userId`: ~38–42 (≈ 40 total users on the platform) - `schoolId`: 36, 37 (≈ 35–37 total schools) - `studentId`: 7849, 7851, 7853 (global counter across tenants)

Combined with **H-3** (certificate 401 vs 404 leak) and **H-2** (signup enumeration) an attacker can enumerate every school's roster.

Fix: Use unguessable public identifiers (UUIDv4 or `nanoid`) in API responses while keeping integer PKs internally. Migrate the `students` table to expose `public_id` (CHAR(21)) and have all routes accept only the public ID.

HIGH findings

H-1 · SEC — Common breached passwords accepted at signup

- `Password1!`, `Abcdefgh1!`, and even `shortVal1` (9 chars, no symbol) all pass `/api/signup`'s policy.
- No HaveIBeenPwned / breach-list check.

Fix: Reject the top 10 000 most-breached passwords (via `zxcvbn` or HIBP k-anonymity API) and require a minimum zxcvbn score of 3.

H-2 · SEC — Account enumeration on /api/signup

A repeat signup with an existing email returns `{"error":"Email already registered"}` while a fresh email returns `{"success":true,"userId":N}`. This lets attackers test whether any email already has an account — including staff emails. (`support@elimupay.co.ke` was **not yet registered** during testing, so anyone can register it now.)

Fix: Always return `{"success":true}` even on duplicates; trigger a "this email is already linked to an account — sign in or reset password" email out-of-band. Reserve common staff identities (`admin@`, `support@`, `billing@`, `noreply@`) at deploy time.

H-3 · SEC — Cross-tenant resource probing leaks existence via 401 vs 404

- `GET /api/certificate?studentId=7849` (own) → 200
- `GET /api/certificate?studentId=999999` (nonexistent) → 404
- `GET /api/certificate?studentId=7851` (other tenant) → **401** `{"error":"Unauthorized"}`

The 401-vs-404 distinction allows enumeration of which `studentId` values exist platform-wide (combined with C-4 sequential IDs).

Fix: Return `404` for both "doesn't exist" and "not in your tenant". Same applies anywhere the API distinguishes these two states.

H-4 · SEC — `/admin/*` routes only enforce auth client-side

`/admin/dashboard`, `/admin/audit`, `/admin/schools`, `/admin/billing`, `/admin/communications`, `/admin/analytics`, `/admin/onboarding`, `/admin/flags`, `/admin/forecast`, `/admin/settings`, `/admin/activity` — all return **HTTP 200** to an unauthenticated request, then a client-side `fetch('/api/admin/me')` redirects to `/login`. The API behind each panel is gated, so this is defense-in-depth not direct data leak, but it differs from the school-tenant routes (`/dashboard`, `/students`, `/invoices`, `/upload`, `/reminders`, `/settings`) which correctly return `307` to `/login`.

Fix: Move admin auth gating into Next.js middleware (or the route's server component) so the page itself returns `307 → /login` for unauthenticated users.

H-5 · SEC — `/admin/setup` exposes a public admin-bootstrap form gated only by a brute-forceable secret

The page at `/admin` renders a "Create your Elimu Pay admin account" form (fields: name, email, password, **secret key**). The backing endpoint `POST /api/admin/setup` accepts unauthenticated POSTs and rejects only on `secretKey` mismatch. There is no "setup already complete" check (same error returned regardless), no rate limit (C-3), and the page is discoverable (`/admin` returns 200 without auth).

Fix: - Lock the endpoint after the first admin exists (`return 403 { generic }` if `admin_users` row count ≥ 1). - Move the secret key to a long random env var and reject the route entirely once the env var is unset post-bootstrap. - IP-allowlist the admin setup endpoint, or remove it from production builds.

H-6 · FUNC — Server accepts invalid email formats at signup

`{"email":"notanemail", …}` was accepted → `{"success":true,"userId":29}` . The user can never be reached by email (verification, password reset, receipts). Data-quality + functional bug.

Fix: Run RFC-5322 / lightweight regex validation server-side. The HTML5 `type="email"` only protects the happy path.

H-7 · FUNC — Upload of an 18 MB CSV hangs forever (likely Vercel function timeout)

The Upload Statement widget advertises "Max 20MB" but an 18 MB CSV upload sits at "Analysing statement…" indefinitely with no client error. Vercel serverless functions default to a 10 s execution timeout (60 s on Pro). The user is given no feedback that processing failed.

Fix: Either (a) raise the function memory/duration and stream/chunk the parse, (b) move large parsing to a background worker (Vercel Queues / Inngest) with a status-poll UI, or (c) advertise a smaller realistic limit (e.g., "Max 4 MB") and reject larger uploads client-side with a clear error.

H-8 · FUNC / SEC — No length limit on signup `name`

A 10 000-character name was accepted with `HTTP 200` . Risk: storage abuse, UI overflow when rendered, log-line size for downstream services, and 4xx amplification (an attacker can pump junk into the DB at signup speed × no rate limit).

Fix: Server-side enforce `name` , `schoolName` ≤ 120 chars; `paybill` regex `^\d{5,7}$` ; `email` ≤ 254 chars; `currentTerm` against an enum.

H-9 · A11Y — `<select>` for current term has no accessible name (`select-name` , **critical**)

Axe-core flags the signup page's term selector as a *critical* WCAG violation:

```
<select class="…"><option>Term 1 2026</option><option selected>Term 2 2026</option>…
</select>
```

No `aria-label`, no wrapping `<label>`, no `aria-labelledby`. Screen-reader users hear only "combobox, Term 2 2026" with no context.

Fix: `<label htmlFor="term">Current term</label><select id="term" …>` or `aria-label="Current term"`.

MEDIUM findings

M-1 · SEC — CSP allows `'unsafe-inline'` and `'unsafe-eval'` in `script-src`

The deployed CSP weakens XSS defense significantly. Migrate to nonces (`'strict-dynamic'` + per-request nonce) using Next.js's built-in CSP nonce feature.

M-2 · SEC — HSTS lacks `preload` and `includeSubDomains` is fine but no preload

Current header: `max-age=31536000; includeSubDomains`. After confirming the canonical `feetracker.co.ke` is HTTPS-only, add `preload` and submit to https://hstspreload.org.

M-3 · SEC — Deprecated `X-XSS-Protection: 1; mode=block` header

Modern browsers ignore or actively misbehave with this header. Set `X-XSS-Protection: 0` or omit.

M-4 · SEO — Sitemap and OG tags point to `feetracker.co.ke` but the build is served from `feetracker-seven.vercel.app`

`robots.txt`, `sitemap.xml`, `og:url`, and `og:image` reference `https://feetracker.co.ke/...`. Until the custom domain is connected, the Vercel preview can be indexed under the wrong canonical, causing duplicate-content / split-PageRank issues. The favicon URL is also malformed: `/favicon.ico?favicon.0x3dzn~oxb6tn.ico?dpl=…` (two `?` separators).

Fix: Either block all crawlers from the `*.vercel.app` host (recommended) by serving `X-Robots-Tag: noindex` when the host is not `feetracker.co.ke`, or wait until DNS cutover before pushing the production OG tags.

M-5 · SEO — No `<link rel="canonical">` on any page

Lighthouse confirms `audit.canonical.score = None` (no canonical found). Add `<link rel="canonical" href="https://feetracker.co.ke{pathname}">` server-side in the root layout.

M-6 · A11Y — Color-contrast (`serious`) on every public page

Specific offenders measured: - "Elimu **Pay**" gold logo: `#c8a84b` on `#ffffff` = **2.29 : 1** (need 4.5 : 1). - Landing-page section eyebrows: `#c8a84b` on `#f8f9fc` = **2.17 : 1**. - Demo dashboard stat labels: `#94a3b8` on `#ffffff` = **2.56 : 1**. - Show/Hide password toggle: `#94a3b8` on `#ffffff` = **2.56 : 1**.

Fix: Either darken `#c8a84b` to `#8d7022` (4.7 : 1) where used on white, or use it only at 18 pt+ (the WCAG large-text threshold) and 3 : 1.

M-7 · A11Y — No `<main>` landmark, content not in regions, /demo has no `<h1>`

All public pages fail axe's `landmark-one-main` and `region` rules. /demo additionally fails `page-has-heading-one`. Wrap each page's primary content in `<main>` and supply a single `<h1>`.

M-8 · A11Y — Signup/login form inputs have no `name`, `id`, or label association

Recon confirmed inputs render as `<input type="email" placeholder="…">` with **no `name`, `id`, `for`, or wrapping `<label>`**. Browsers' autofill heuristics and password managers depend on these; screen readers also need the explicit linkage.

Fix: `<label htmlFor="email">Email</label><input id="email" name="email" type="email" autoComplete="email">` (and similar for `current-password`, `new-password`, `tel`, `organization`). Same pattern for signup name and paybill.

M-9 · SEC — `/api/upload` returns 500 with `"Something went wrong processing your file."` for malformed input

HTML-content-as-`.csv` and JSON sent to `POST /api/students` both produce a 500 with a misleading "processing your file" message even when the request was JSON, not multipart. This (a) leaks parser failure state, (b) generates noise in error monitoring, and (c) misleads developers who are debugging legitimate integrations.

Fix: Return `400 { error: "Unrecognized statement format" }` from validated parser failures; reserve 500 for genuine server bugs.

M-10 · SEC — WhatsApp reminder text reflects raw parent/student names from CSV import

The reminder template is `"Dear ${parentName}, this is a reminder that ${studentName} (${class} ${stream}) has an outstanding fee balance of KES ${amount}…"`. The CSV import accepted `parentName="=2+5"` and stored it; the WhatsApp deep link then included it verbatim. While WhatsApp does not execute formulas, the message is sent under the school's brand, so a malicious or compromised CSV (e.g., from an outgoing IT vendor) can inject arbitrary text to parents.

Fix: Strip leading `=`, `+`, `-`, `@`, `\t`, `\r` from parent and student names at import; reject names containing newlines or control chars; cap names at 80 chars.

M-11 · SEO — No structured data (JSON-LD)

No `Organization`, `Product`, `SoftwareApplication`, or `FAQPage` JSON-LD found. For a Kenya-focused SaaS, adding `Organization` and `SoftwareApplication` will improve search-result rich cards.

M-12 · UX — No `<meta name="theme-color">`, no manifest, no apple-touch-icon

Lighthouse PWA / installability concerns. Add `manifest.json`, `apple-touch-icon-180.png`, and `<meta name="theme-color" content="#0a1f4e">` (the navy used in the header).

M-13 · SEC — Privacy policy missing Kenya DPA (2019) references

The policy lists Vercel as the only processor but does not mention WhatsApp (despite parent-data integration), does not reference the **Office of the Data Protection Commissioner (ODPC)** complaint procedure, the lawful basis for processing under the **Kenya Data Protection Act 2019**, or the company's data-protection officer. Since the product targets Kenyan schools, ODPC alignment is required.

Fix: Add: (1) ODPC contact and complaint procedure, (2) lawful basis (consent for parent contact data; contract for school admin data), (3) data-retention windows beyond financial records, (4) DPO contact, (5) list WhatsApp as a third-party processor.

M-14 · SEC — `robots.txt` does not deny `/admin/*`; admin pages return 200 to crawlers

`robots.txt` allows `/` and sitemap doesn't include `/admin/*`, but the pages still return 200 without auth (H-4). A crawler will discover and index them.

Fix: Add `Disallow: /admin` and `Disallow: /dashboard` etc. to `robots.txt`, and serve `X-Robots-Tag: noindex` from the admin route handler.

LOW / Informational

L-1 · PERF — Lighthouse opportunities (small but worth shipping)

- **Unused JavaScript ≈ 29 KiB** (most of it inside the largest chunk). Code-split the dashboard from the marketing pages.
- **Legacy JavaScript ≈ 14 KiB** — enable the modern bundle output (`browserslist` excluding IE / old Safari).
- **DOM size** 181 elements ✓, **total byte weight** 236 KiB ✓, text compression ✓, modern image formats ✓.

- Mobile LCP element is the hero `<p>` (text) — already excellent.

L-2 · SEC — `/api/admin/setup` discloses "Invalid secret key" rather than a generic error

Combined with no rate limit (C-3), an attacker knows the request shape is correct and only the secret is wrong. Return a single generic `403` regardless of cause.

L-3 · SEC — `Access-Control-Allow-Origin: *` on HTML responses

Harmless for public pages but a misconfiguration smell. Authenticated JSON endpoints correctly echo the origin (`Access-Control-Allow-Origin: https://feetracker-seven.vercel.app`).

L-4 · UX — Signup submit handler did not redirect post-success in headless tests

The signup form moved to "Creating account…" but the page did not navigate after submission in headless Chromium. Manual login afterwards worked, so the row was created — but the user is given no positive confirmation. A short "Account created, signing you in…" toast + an explicit `router.push("/dashboard")` would close this gap.

L-5 · UX — Favicon URL malformed (`?favicon.0x3dzn~oxb6tn.ico?dpl=…`)

Two `?` separators in one URL. Browsers tolerate it but it's a code smell; fix the asset pipeline so it emits `?dpl=…&favicon=…` .

L-6 · Positive — Multi-tenant isolation on `/api/students/{id}` works

Cross-tenant GET/PATCH/PUT/DELETE on every student-ID variant from the other tenant returns `404 {"error":"Student not found"}` — correctly indistinguishable from "doesn't exist". Same for `/api/school?id=<other>` (server ignores the query and serves the requester's school).

L-7 · Positive — Not vulnerable to CVE-2025-29927 (Next.js middleware bypass)

`x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware` against `/dashboard` and `/api/admin/me` returns the same `307` / `401` as without the header. Likely the deployed Next.js version is patched (≥ 14.2.25 / 15.2.3).

L-8 · Positive — Session cookies properly hardened

NextAuth issues `__Host-authjs.csrf-token` , `__Secure-authjs.callback-url` , `__Secure-authjs.session-token` — all `Secure` , `HttpOnly` , `SameSite=Lax` . SameSite=Lax + the absence of third-party POST surfaces gives effective CSRF protection without an explicit token on most application routes.

L-9 · Positive — No source maps, no `__NEXT_DATA__` secrets exposed

`/.git/`, `/.env`, `/package.json`, `/next.config.js`, `/api/health`, `/api/version`, `/admin/audit`, `/admin/schools` source-map requests all 404. The JS bundles do not contain any visible `mpesa_*`, `consumer_key`, `consumer_secret`, `supabase`, `sk_live`, `whatsapp`, `bearer`, or JWT-shape (`eyJ…`) strings.

L-10 · Positive — Forgot-password endpoint is enumeration-safe

`POST /api/forgot-password` returns `{"success":true}` for both known and unknown emails with similar timing (500–650 ms).

L-11 · Positive — Excel report download is sanitized

The 23 KiB XLSX downloaded from `/api/report` was inspected; no formula-injection payloads round-tripped from CSV import.

L-12 · Positive — File-extension whitelist enforced on Upload Statement

`.exe` correctly rejected with `400 "Only .xlsx, .xls, .csv, and .pdf files are accepted"`.

L-13 · Positive — Mobile Core Web Vitals all in "Good" range

- LCP 2.02 – 2.13 s · FCP 0.84 – 1.41 s · CLS 0.00 · TBT 195 – 355 ms
- Desktop perf 100/100 on all four tested pages.

Test accounts and resources to purge before launch

Created during testing (please delete the corresponding `users` and `school` rows):

Type	Identifier	Notes
User	`userId` ≈ **14 – 30**	Password-policy probes, weak-password tests, duplicate-email/invalid-email probes; emails were `*@example.com` random aliases.
User	`userId` 31, 32	Duplicate-paybill PoC for C-2 (paybill `555666`).
User	`userId` 33, 34	SQLi/XSS string probes in name and schoolName (data is benign — both stored verbatim, neither caused execution).
User	`userId` 38, `schoolId` 36	**QA School Alpha** — `qa-school-alpha-1778843783@elimupay-qa.invalid` (paybill `700001`). Contains 5 student rows: ids 7849, 7850, 7853, 7854, 7855.
User	`userId` 39, `schoolId` 37	**QA School Beta** — `qa-school-beta-1778843783@elimupay-qa.invalid` (paybill `700002`). Contains 2 student rows: ids 7851, 7852.
Other	userIds 35 – ~42	A handful of additional one-off signups during enumeration/duplicate-paybill probing.

All test emails end in `@example.com` or `@elimupay-qa.invalid` so a `WHERE email LIKE '%@example.com' OR email LIKE '%@elimupay-qa.invalid'` SQL filter will purge cleanly. Also delete the M-Pesa statement upload artifacts from Alpha's tenant (formula-injection CSV) so they don't appear in any audit / report.

Methodology & tools used

- **Passive recon:** `curl` (header sweep, CSP/HSTS/CORS), `Grep` over downloaded `_next/static/chunks/*.js` (secret + endpoint enumeration), explicit probes against `~50` candidate paths (`/.env`, `/api/admin/*`, sitemap-listed URLs, NextAuth conventions).
- **Active auth tests:** scripted POSTs to `/api/auth/callback/credentials`, `/api/auth/csrf`, `/api/signup`, `/api/admin/setup`, `/api/forgot-password`.
- **Browser automation:** Python Playwright 1.59 + Chromium headless. See `.qa/01b_signup_via_api.py`, `.qa/03_students_csv_import.py`, `.qa/04_idor_v2.py`, `.qa/05_upload_abuse.py`, `.qa/06_rendered_views.py`, `.qa/07_report_and_unmatched.py`.
- **Accessibility:** axe-core 4.10.2 injected via Playwright across `/`, `/demo`, `/login`, `/signup`, `/privacy`, `/forgot-password`. Raw JSON results in `.qa/network/axe_*.json`; summary in `.qa/axe_summary.json`.
- **Performance:** Lighthouse 12.8.2 (`npx lighthouse`) mobile + desktop on `/`, `/demo`, `/login`, `/signup`. Raw reports in `.qa/lighthouse/`.
- **Multi-tenant isolation:** two disposable schools (Alpha = `schoolId` 36, Beta = `schoolId` 37) populated with students via CSV import; then with each session's cookies attempted GET/PATCH/PUT/DELETE on the other tenant's student, certificate, invoice, and school endpoints.

- **CVE check:** CVE-2025-29927 verified via `x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware` header replay against gated routes.

All raw artifacts (screenshots, network logs, HTML dumps, Lighthouse reports, axe results, downloaded XLSX) live under `.qa/` in this directory.

Out of scope (not tested)

- Real **M-Pesa Daraja** callback ingestion (would require Safaricom sandbox creds + the platform's webhook URL).
- Real **WhatsApp Business API** sending (no business-account creds shared; only the `wa.me/` deep-link path tested).
- **Load / stress** testing (could affect any other live tenants on the deployment).
- **Source-code review** (no repo was provided in the working directory).
- **Network / infra pentest** of Vercel itself (out of bounds).
- **Browser cross-compat** beyond Chromium (Firefox / WebKit not re-run for the dynamic flows; Lighthouse rendered via Chromium only).
- The **2FA enrollment + verification** flow (the field is present in `/api/account` but enrollment UI was not exercised).

Recommended pre-launch sequencing

1. **Fix today** (blocks launch): C-1 phone normalization, C-2 paybill uniqueness, C-3 rate limits, H-5 admin setup endpoint lockdown, M-4/M-5 canonical/OG host before DNS cutover.
2. **Fix this week** (high-value): C-4 ID opacity, H-1 password policy, H-2 enumeration, H-3 cert IDOR leak, H-4 admin SSR gate, H-6 email validation, H-7 upload size feedback, H-8 input length caps, H-9 select-name.
3. **Fix this sprint** (defense in depth + WCAG AA): M-1 CSP nonces, M-6 contrast, M-7 landmarks, M-8 form semantics, M-9 error semantics, M-10 deep-link sanitization, M-13 Kenya DPA, M-14 robots block on /admin.
4. **Polish backlog**: L-series — small perf savings, generic error wording, JSON-LD, manifest/theme-color, post-signup UX.

© 2026 Datacare Limited · info@datacare.co.ke